Sécurité des systèmes : Androids

Rapport Backlog - sécurité Android

https://github.com/Thonatflo3/SDS-A

Thommy DUVAL, Florent PORLIER-PAGNON, Nathan DUVINAGE

29/04/2026

Intro

Projet : Analyse et sécurisation d’une application Android — de la récupération jusqu’au reporting et à la politique mobile.

Objectifs pédagogiques :

Savoir récupérer un APK vulnérable, faire de l’analyse statique (manuelle + outils automatisés), décompiler/recompiler/Signer un APK, détecter fuites (strings.xml, Firebase…), produire un rapport de vulnérabilités et définir des mesures organisationnelles (politique mobile + choix MDM).

Stories

U.S 1

Téléchargement et vérification de l'APK

En tant que testeur
Je veux recevoir l'APK vulnérable fourni par le PO
Afin de travailler sur une base commune

DoD :
Chaque étudiant vérifie le hash avec `sha256sum app.apk` et documente le résultat.

Nous obtenons le résultat car le fichier est le même et une fonction de hachage génère un hash unique basé sur le contenu du fichier (.apk ici).

```
root@DebianLaptopFlo /home/fporlier/AndroidSecu/APKMALWARE# sha256sum app.apk
f01f08c8b6e2fe4612e81bc7e3a3ba9440dad0d7a962f4e67640390dd721d528  app.apk
root@DebianLaptopFlo /home/fporlier/AndroidSecu/APKMALWARE#
```

```
┌──(kali㉿kali)-[~/Downloads]
└─$ sha256sum app.apk
f01f08c8b6e2fe4612e81bc7e3a3ba9440dad0d7a962f4e67640390dd721d528  app.apk
```

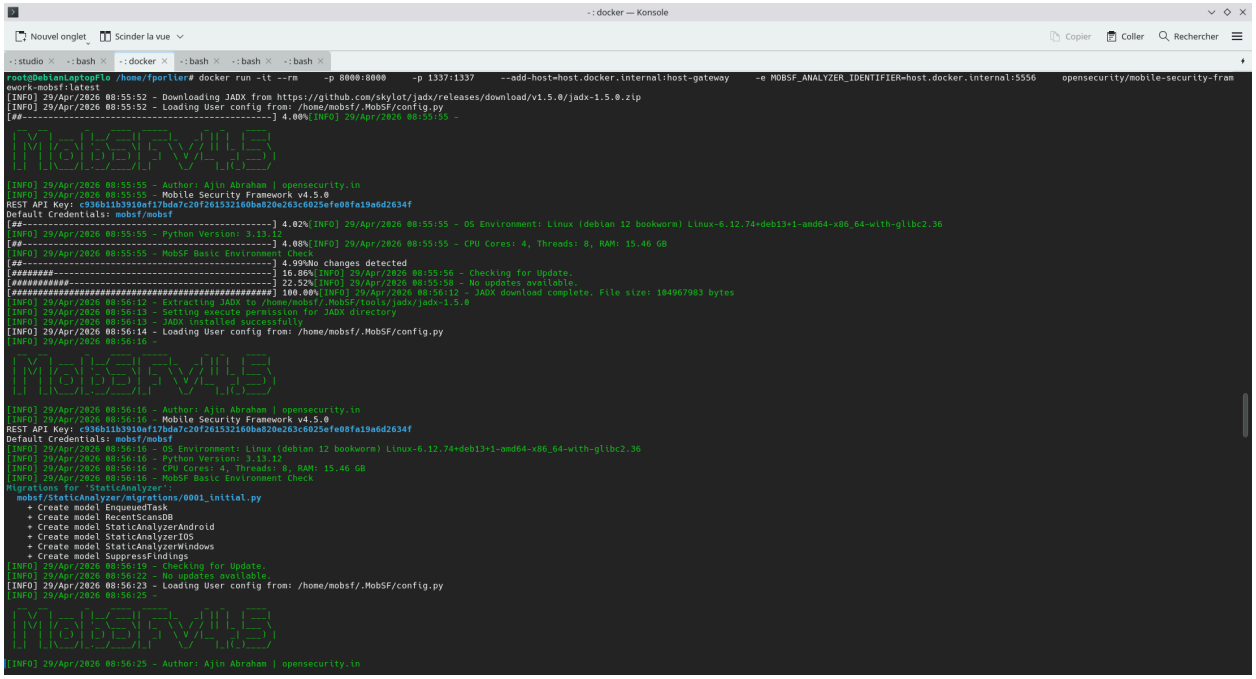
U.S 2

Analyse automatisée avec MobSF

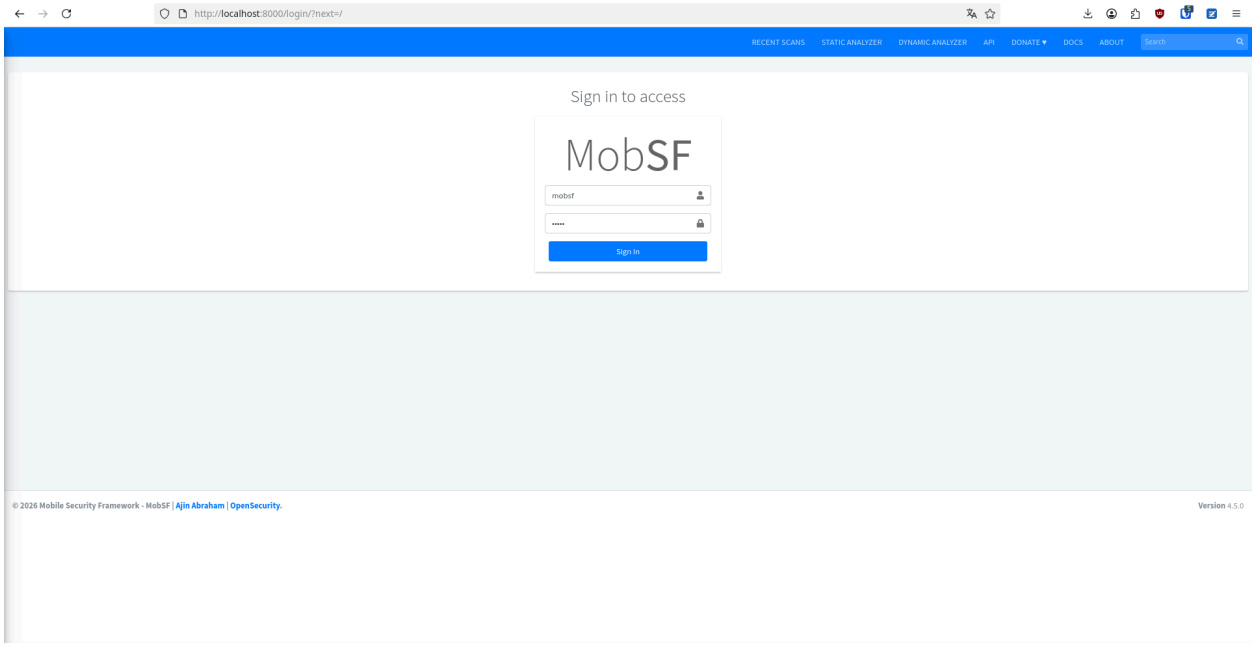
En tant que analyste
Je veux scanner l'APK avec MobSF
Afin de identifier rapidement métadonnées et vulnérabilités

DoD :
mobSF_report.pdf + résumé des vulnérabilités

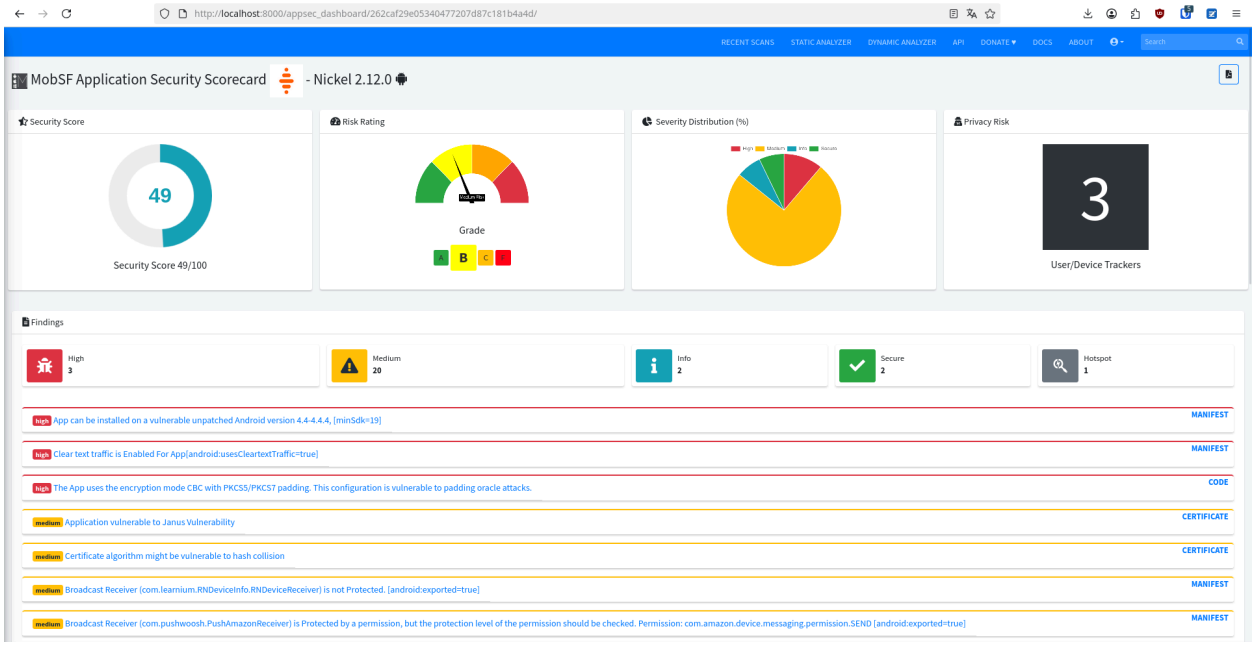
Démarrage du conteneur docker mobsf :



Interface web MobSF



Résultat analyse statique fichier APK :



L’application présente plusieurs vulnérabilités critiques : communications non chiffrées, utilisation d’un chiffrement vulnérable (CBC) et compatibilité avec des versions Android non sécurisées.

De nombreuses failles de configuration exposent des composants Android (services, receivers, content provider) sans protection.

On note également des risques applicatifs importants : SQL Injection, génération aléatoire non sécurisée, stockage externe exposé et utilisation d'algorithmes faibles (MD5).

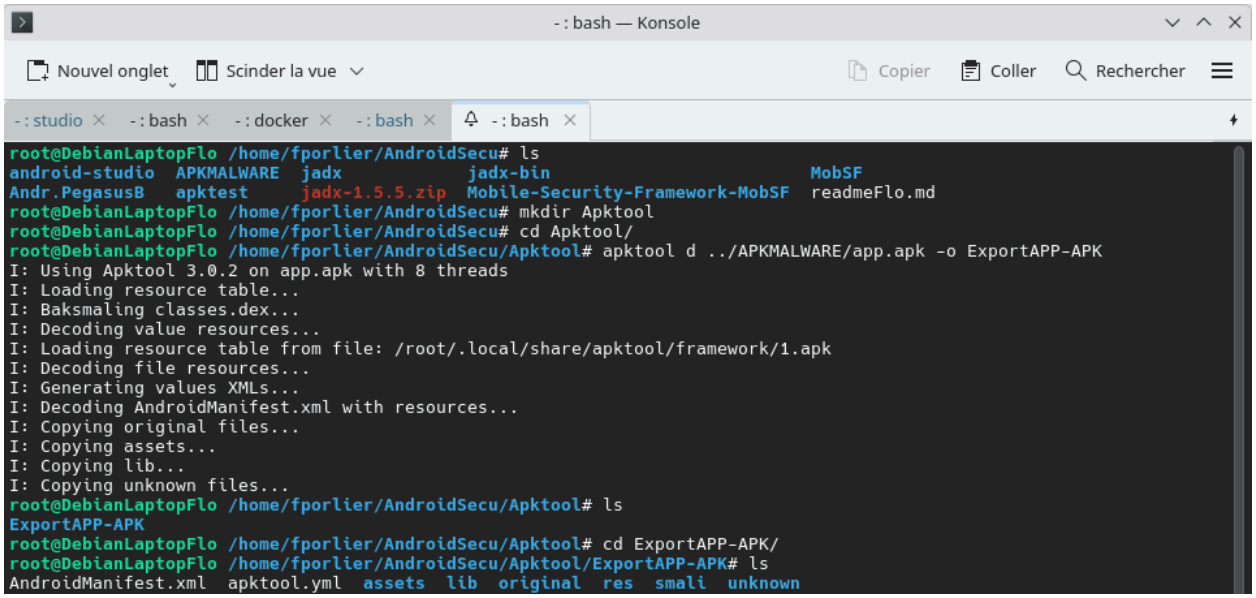
Enfin, des données sensibles peuvent être exposées (logs, fichiers temporaires, secrets en dur) et l'application contient des trackers impactant la confidentialité.

U.S 3

Extraction de fichiers

En tant que reverse-engineer
Je veux extraire `classes.dex` / `Manifest.xml` de l'APK
Afin de préparer une décompilation

DoD :
Fichiers livrés avec hash SHA256



Exporter le classes.dex :

```
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool/ExportAPP-APK# unzip ../../APKMALWARE/app.apk classes.dex -d
 /home/fporlier/AndroidSecu/Apktool/ExportAPP-APK/original/
Archive:  ../../APKMALWARE/app.apk
  inflating: /home/fporlier/AndroidSecu/Apktool/ExportAPP-APK/original/classes.dex
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool/ExportAPP-APK# ls
AndroidManifest.xml  apktool.yml  assets  lib  original  res  smali  unknown
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool/ExportAPP-APK# cd original/
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool/ExportAPP-APK/original# ls
AndroidManifest.xml  classes.dex  META-INF
```

Pour le sha256sum des 2 fichiers :

```
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool/ExportAPP-APK/original# sha256sum /home/fporlier/AndroidSecu/Apktool/ExportAPP-APK/original/classes.dex
sha256sum /home/fporlier/AndroidSecu/Apktool/ExportAPP-APK/original/AndroidManifest.xml
57898c5978715da96560ed2692b4a8fa1a8e914b37988dcf369cc59951f6c429  /home/fporlier/AndroidSecu/Apktool/ExportAPP-APK/original/classes.dex
80b9b101e3bf02f03eec4f2c9c9ccf4d61403612e1435949b51cec8b85d7a276  /home/fporlier/AndroidSecu/Apktool/ExportAPP-APK/original/AndroidManifest.xml
```

U.S 4

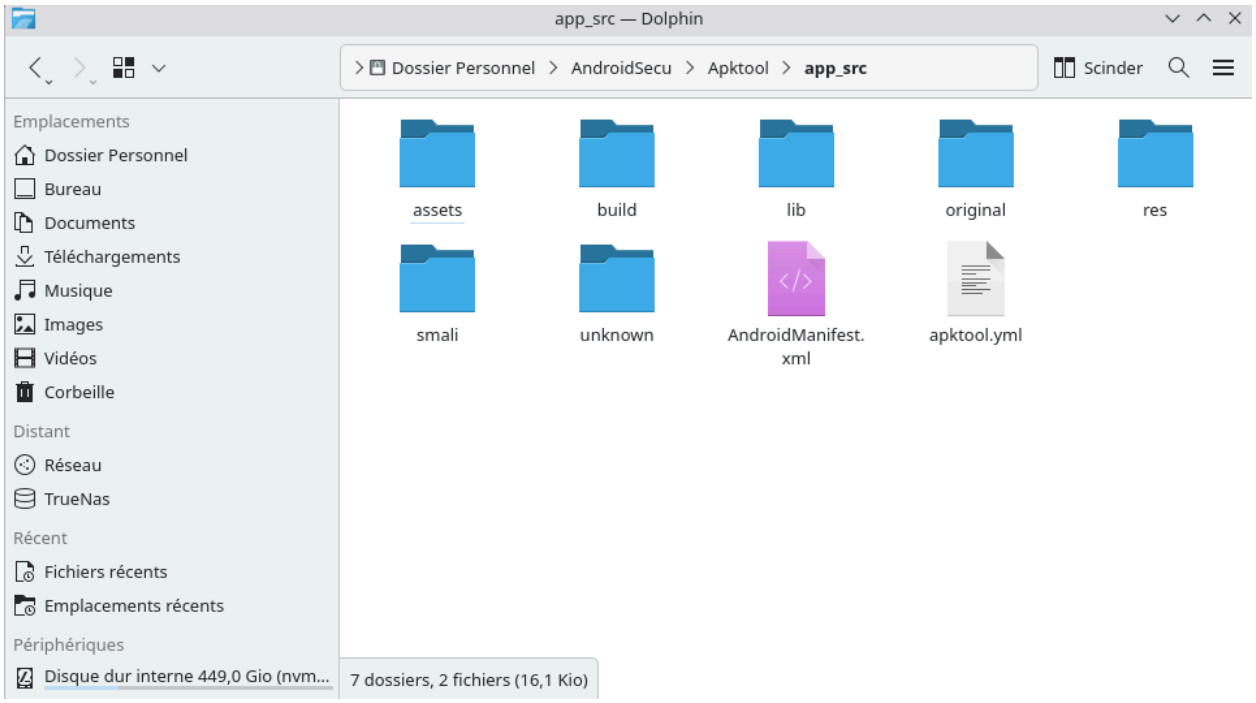
Décompilation avec Apktool

En tant que auditeur
Je veux décompiler l'APK avec Apktool
Afin de accéder aux ressources et au manifest

DoD :
Dossier `app_src/` livré (zippé)

Commande pour décompiler le .apk avec apktool :

apktool d /chemin/vers/ton.apk -o /home/fporlier/AndroidSecu/Apktool/ExportAPP-APK/



Ensuite on peut naviguer pour aller chercher nos fichiers dans le dossier source de l'application

Pour renommer : mv ExportAPP-APK app_src Pour zipper : zip -r app_src.zip app_src/
Pour vérifier : ls -lh app_src.zip
Pour le hash :

```
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlob.smali (deflated 88%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlobReq$3.smali (deflated 81%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlobFS.smali (deflated 90%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlobBody$1.smali (deflated 75%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlobUtils$1.smali (deflated 65%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlob$10.smali (deflated 72%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlob$3.smali (deflated 73%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlobBody.smali (deflated 88%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlob$7.smali (deflated 73%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlob$12.smali (deflated 63%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlobReq$1.smali (deflated 68%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlob$8.smali (deflated 75%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlobPackage.smali (deflated 71%)
  adding: app_src/smali/com/RNFetchBlob/RNFetchBlob$2.smali (deflated 74%)
  adding: app_src/AndroidManifest.xml (deflated 83%)
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool# ls -lh app_src.zip
-rw-rw-r-- 1 root root 33M 29 avril 11:23 app_src.zip
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool# sha256sum app_src.zip
fd578c26f7fbd37678b04e7eb6548470b8e3b22737cc901167c4aa1e6a7552ee  app_src.zip
```

U.S 5

Analyse de strings.xml

En tant que analyste sécurité
Je veux analyser `strings.xml`
Afin de repérer secrets ou informations critiques en clair

DoD :
`strings_findings.md` avec extraits (≤25 mots) et risques associés

Cf USR5 sur github.

U.S 6

Recompilation de l'APK

En tant que développeur
Je veux recompiler l'APK avec Apktool
Afin de vérifier que la décompilation est réversible

DoD :
Fichier livré + log de build

Commandes pour recompiler

```
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool# ls
app_src  app_src.zip
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool# apktool b app_src/ -o app_recompiled.apk 2>&1 | tee build.l
og
I: Using Apktool 3.0.2 on app.apk with 8 threads
I: Smaling smali folder into classes.dex...
I: Building resources with aapt2...
I: Building apk file...
I: Importing assets...
I: Importing lib...
I: Importing unknown files...
I: Built apk into: app_recompiled.apk
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool#
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool# ls -lh app_recompiled.apk
-rw-rw-r-- 1 root root 23M 29 avril 13:13 app_recompiled.apk
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool#
```

Pour le hash et le fichier de log :

```
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool# sha256sum app_recompiled.apk
177589d2d33b94cf8c3889eeb5f257680d3880a1e667c4f0d87735f0cbb91c29  app_recompiled.apk
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool# cat build.log
I: Using Apktool 3.0.2 on app.apk with 8 threads
I: Smaling smali folder into classes.dex...
I: Building resources with aapt2...
I: Building apk file...
I: Importing assets...
I: Importing lib...
I: Importing unknown files...
I: Built apk into: app_recompiled.apk
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool# ls -lh
total 56M
-rw-rw-r-- 1 root root  23M 29 avril 13:13 app_recompiled.apk
drwxrwxr-x 9 root root 4,0K 29 avril 13:13 app_src
-rw-rw-r-- 1 root root  33M 29 avril 11:23 app_src.zip
-rw-rw-r-- 1 root root  264 29 avril 13:13 build.log
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool#
```

U.S 7

Signature de l'APK

En tant que testeur
Je veux signer l'APK recompilé
Afin de pouvoir l'installer sur un émulateur ou terminal

DoD :
`rebuilt_signed.apk` livré + preuve `apksigner verify`

Commandes :

1 : Générer un keystore de test

```
keytool -genkeypair \

  -alias mobsf_test \

  -keyalg RSA \

  -keysize 2048 \

  -validity 365 \

  -keystore test.keystore \

  -storepass mobsf123 \

  -keypass mobsf123 \

  -dname "CN=MobSF Test, OU=Security, O=Test, L=Paris, ST=IDF, C=FR"
```

```
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool# keytool -genkeypair \
  -alias mobsf_test \
  -keyalg RSA \
  -keysize 2048 \
  -validity 365 \
  -keystore test.keystore \
  -storepass mobsf123 \
  -keypass mobsf123 \
  -dname "CN=MobSF Test, OU=Security, O=Test, L=Paris, ST=IDF, C=FR"
Génération d'une paire de clés RSA de 2 048 bits et d'un certificat auto-signé (SHA384withRSA) d'une validité de 365
 jours
        pour : CN=MobSF Test, OU=Security, O=Test, L=Paris, ST=IDF, C=FR
```

2 : Aligner l'APK avec zipalign

```
/root/Android/Sdk/build-tools/36.0.0/zipalign \

  -v 4 app_recompiled.apk app_aligned.apk
```

3 : Signer avec apksigner

```
/root/Android/Sdk/build-tools/36.0.0/apksigner sign \

  --ks test.keystore \

  --ks-pass pass:mobsf123 \

  --key-pass pass:mobsf123 \

  --ks-key-alias mobsf_test \

  --out rebuilt_signed.apk \

  app_aligned.apk
```

```
Verification successful
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool# /root/Android/Sdk/build-tools/36.0.0/apksigner sign \
  --ks test.keystore \
  --ks-pass pass:mobsf123 \
  --key-pass pass:mobsf123 \
  --ks-key-alias mobsf_test \
  --out rebuilt_signed.apk \
  app_aligned.apk
root@DebianLaptopFlo /home/fporlier/AndroidSecu/Apktool# /root/Android/Sdk/build-tools/36.0.0/apksigner verify \
  -v rebuilt_signed.apk
Verifies
Verified using v1 scheme (JAR signing): true
Verified using v2 scheme (APK Signature Scheme v2): true
Verified using v3 scheme (APK Signature Scheme v3): true
Verified using v3.1 scheme (APK Signature Scheme v3.1): false
Verified using v4 scheme (APK Signature Scheme v4): false
Verified for SourceStamp: false
Number of signers: 1
WARNING: META-INF/androidx.viewpager2_viewpager2.version not protected by signature. Unauthorized modifications to t
his JAR entry will not be detected. Delete or move the entry outside of META-INF/.
WARNING: META-INF/androidx.transition_transition.version not protected by signature. Unauthorized modifications to t
his JAR entry will not be detected. Delete or move the entry outside of META-INF/.
```

U.S 8

Vérification Firebase

En tant que pentesteur
Je veux tester l'accès public à une éventuelle base Firebase
Afin de évaluer le risque de fuite de données

DoD :
`firebase_check.md` + capture de la réponse

CF USR8 sur github

U.S 9

Rapport technique

En tant que consultant sécurité
Je veux rédiger un rapport structuré
Afin de présenter findings, preuves et recommandations

DoD :
`rapport_final.pdf` livré

U.S 10

Politique de sécurité mobile

En tant que responsable sécurité
Je veux proposer une politique mobile
Afin de encadrer le développement et l'usage des apps mobiles

DoD :
`politique_mobile` livré

Règles de sécurité

Gestion des appareils

- Enrôlement obligatoire dans un MDM
- Verrouillage (PIN ≥ 6 chiffres ou biométrie)
- Root/jailbreak interdit

Gestion des applications

- Installation uniquement via sources officielles
- Sideloading interdit
- Mises à jour obligatoires

Protection des données

- Chiffrement du stockage obligatoire
- Interdiction des données sensibles en clair
- Utilisation du Keystore Android

Sécurité réseau

- HTTPS obligatoire (TLS 1.2+)
- VPN requis hors réseau interne
- Wi-Fi public interdit sans protection

Sécurité applicative

- Obfuscation du code
- Debug désactivé en production
- Certificate pinning recommandé

Gestion des incidents

- Wipe à distance possible
- Blocage appareil
- Journalisation des événements

U.S 11

Choix d'une solution MDM

En tant que architecte sécurité
Je veux comparer 2 solutions MDM
Afin de recommander la plus adaptée

DoD :
`mdm_recommandation` livré avec tableau comparatif

Comparatif

Critère	Microsoft Intune	Workspace ONE
Intégration SI	Très bonne	Bonne
Facilité d'utilisation	Élevée	Moyenne
Sécurité	Élevée	Élevée
Gestion Android	Bonne	Très bonne
Coût	Modéré	Élevé

Analyse

- Intune : solution simple, bien intégrée aux environnements Microsoft
- Workspace ONE : plus complète mais plus complexe

Recommandation

Microsoft Intune est retenu pour sa simplicité, son intégration et son efficacité.

U.S 12

Installation MDM & enrôlement (bonus)

En tant que administrateur IT
Je veux installer une solution MDM et enrôler un smartphone
Afin de appliquer et vérifier une politique de sécurité

DoD :

- Un device enrôlé visible dans la console avec statut conforme
- Captures écran montrant l'application de la politique